

# MISE EN PLACE ET SÉCURISATION D'UNE INFRASTRUCTURE AD



DÉCEMBRE 2025

# Sommaire

## 1. Choix de la solution serveur

- Pourquoi Windows Server 2025 a été retenu
- Cycles de vie des différentes versions de Windows Server
- Avantages de Windows Server 2025
- Support actif et mises à jour de sécurité étendues

## 2. Arborescence de votre infrastructure

- Structure hiérarchique et logique de l'infrastructure Active Directory
- Domaine "pipalap.net" et son organisation par bâtiment

## 3. Convention de nommage

- Convention de nommage pour les GPO
- Exemple de mot de passe utilisateur et explication de la structure
- Bonnes pratiques pour les mots de passe
- Politique de sécurité (méthodologie de cloisonnement, principes CIA)

## 4. Script pour la création d'utilisateur

- Description du script PowerShell pour la création d'utilisateurs
- Exécution du script et configuration du chemin d'unité d'organisation (OU)
- Stratégie de sauvegarde et de disponibilité (méthode 3-2-1-1-0)

## 5. Gestion de droits de fichiers

- Méthode AGDLP pour la gestion des groupes et des accès
- Exemple d'application de la méthode AGDLP pour Clara et Nadia

## 6. Besoins clients

- Demande pour un fond d'écran commun
- Protection contre la vulnérabilité *PrintNightmare* avec GPO de protection

## 7. Stratégie de sécurité et mise en place des protections

- Actions pour se protéger contre la vulnérabilité PrintNightmare
- Désactivation du service Spouleur d'impression et configurations de sécurité

## 8. Indice de performance avec PingCastle

- Objectif de PingCastle et son rôle dans l'audit de sécurité AD

## 9. Poste Linux et intégration avec Active Directory

- Procédure pour joindre une machine Linux à un domaine Active Directory
- Étapes détaillées pour configurer et vérifier la jonction du domaine

---

## Choix de la solution serveur

À ce jour, l'utilisation de Windows Server 2025 a été retenue car il s'agit de la version la plus récente disposant d'un cycle de support long et sécurisé. Cette version garantit un support actif jusqu'au 9 octobre 2029 et des mises à jour de sécurité étendues jusqu'au 10 octobre 2034, assurant ainsi la pérennité, la sécurité et la conformité de l'infrastructure sur le long terme.

<https://endoflife.date/windows-server>

| Libérer                    | Libéré                          | Soutien actif                                   | Soutien à la sécurité                                          | Mises à jour de sécurité étendues | Dernier                    |
|----------------------------|---------------------------------|-------------------------------------------------|----------------------------------------------------------------|-----------------------------------|----------------------------|
| Windows Server 2025 (LTSC) | il y a un an (01 novembre 2024) | Se termine dans 3 ans et 10 mois (09 oct. 2029) | Se termine dans 8 ans (10 oct. 2034)                           | Indisponible                      | <a href="#">10.0.26100</a> |
| Windows Server 23H2 AC     | il y a 2 ans (24 oct. 2023)     | Terminé il y a 7 mois (24 avril 2025)           | Cela s'est terminé il y a 1 mois et 3 semaines. (24 oct. 2025) | Indisponible                      | <a href="#">10.0.25398</a> |
| Windows Server 2022 (LTSC) | il y a 4 ans (18 août 2021)     | Se termine dans 10 mois (13 oct. 2026)          | Se termine dans 5 ans et 10 mois (14 oct. 2031)                | Indisponible                      | <a href="#">10.0.20348</a> |
| Windows Server 20H2 SAC    | il y a 5 ans (20 oct. 2020)     | Cela s'est terminé il y a 3 ans (09 août 2022)  | Cela s'est terminé il y a 3 ans (09 août 2022)                 | Indisponible                      | <a href="#">10.0.19042</a> |

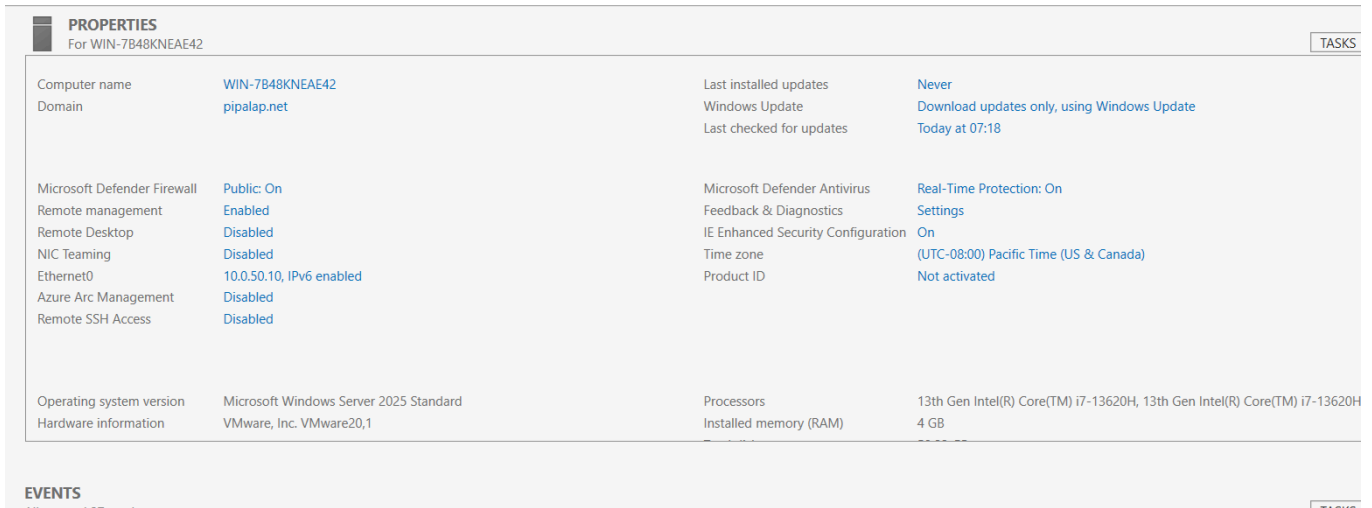
Cette image met en évidence les cycles de vie des différentes versions de **Windows Server**. On constate que plusieurs versions encore présentes dans certaines infrastructures (Windows Server 2019, 2022 ou 23H2) approchent de la **fin de leur support actif**, voire sont déjà sorties de ce cycle.

Dans ce contexte, **Windows Server 2025** se distingue comme la solution la plus pérenne :

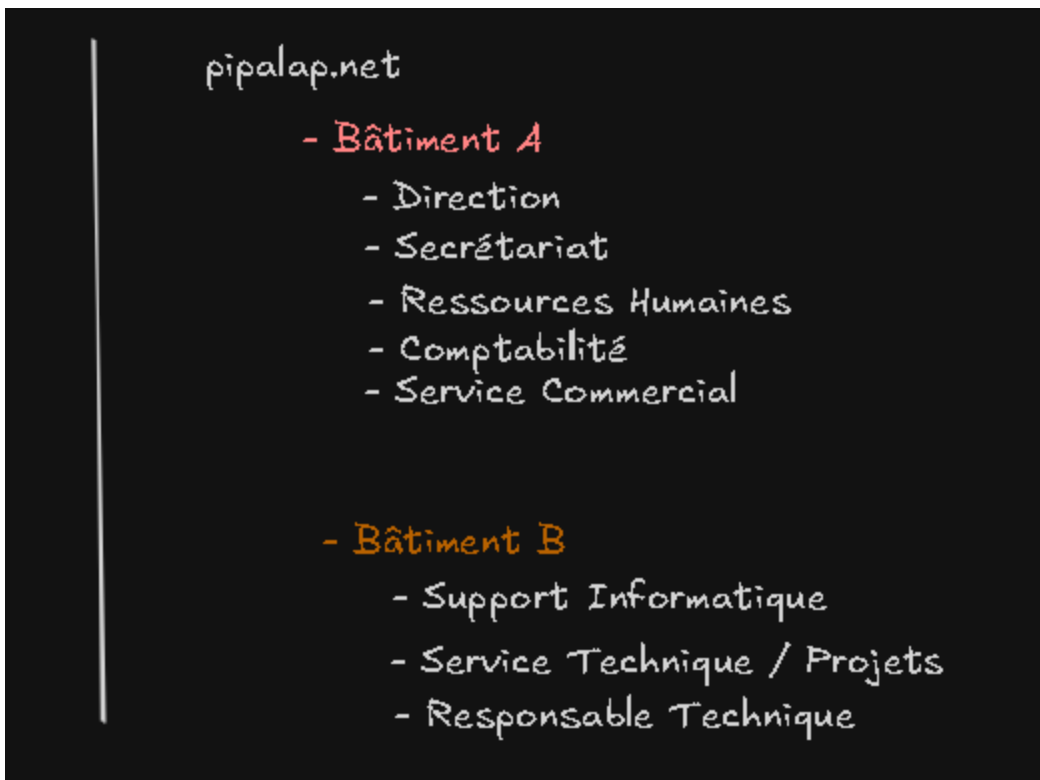
- support actif garanti jusqu'en **octobre 2029**,
- mises à jour de sécurité étendues jusqu'en **octobre 2034**.

Le choix de Windows Server 2025 permet donc :

- d'éviter toute situation d'**obsolescence à court ou moyen terme**,
- de garantir la **sécurité** de l'Active Directory et des services critiques,
- d'assurer la **conformité** avec les bonnes pratiques et exigences actuelles,
- et de limiter les coûts et risques liés à une migration prématurée.



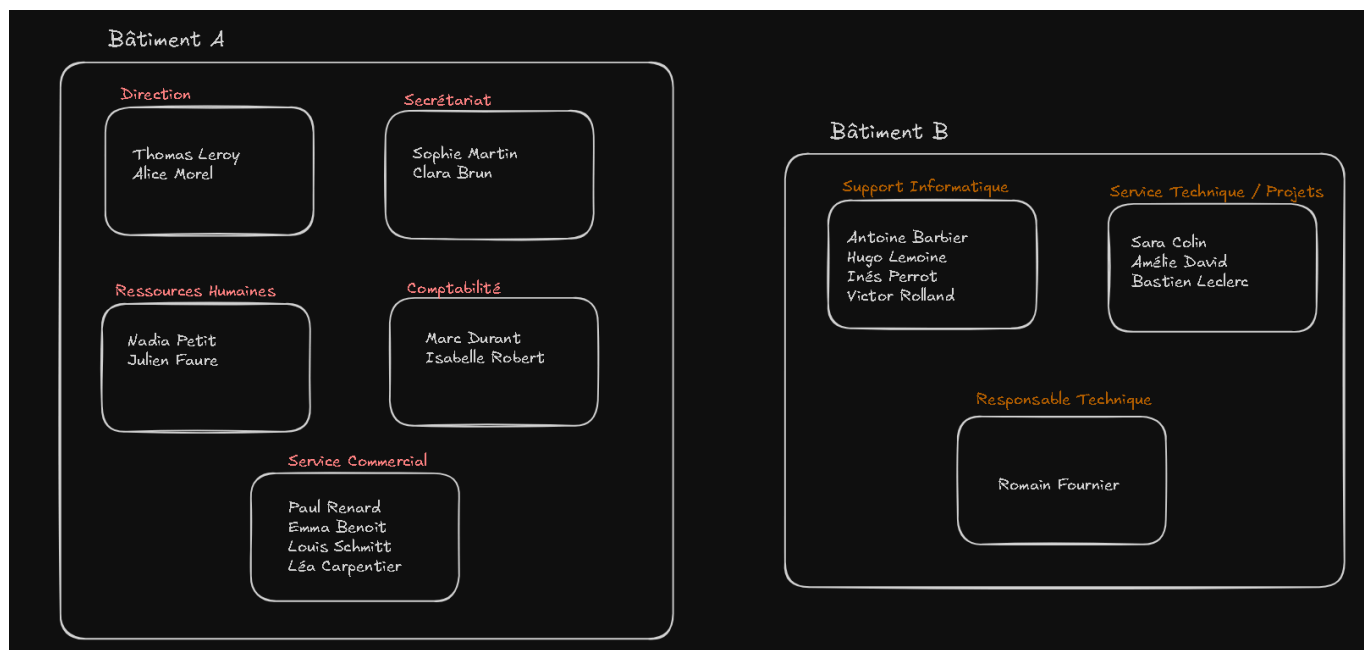
## Arborescence de votre infrastructure



L'infrastructure Active Directory est organisée de manière **hiérarchique et logique** afin de faciliter l'administration, renforcer la sécurité et appliquer efficacement les stratégies de groupe (GPO).

Le domaine **pipalap.net** constitue la racine de l'annuaire. Il est ensuite structuré par **bâtiment**, ce qui permet de refléter l'organisation physique de l'entreprise tout en simplifiant la gestion des

utilisateurs et des ressources.



## Convention de nommage

Convention de nommage pour les GPO :

*client* → *utilisateur* → *contexte* → *UO* → *Bâtiment* → *Service*

Exemple : **CL-U-Desktop-UO-BA-Compta**

Mot de passe utilisateur:

*2 première lettre du nom* → *2 première lettre du prénom* → *PC* → *numéro du service*

Direction : **1**

Secrétariat : **2**

Ressources Humaines : **3**

Comptabilité : **4**

Service Commercial : **5**

Support Informatique : **6**

Service Technique / Projets : **7**

Responsable Technique : **8**

| Élément | Description                          |
|---------|--------------------------------------|
| TH      | 2 premières lettres du prénom        |
| LE      | 2 premières lettres du nom           |
| 09      | Nombre aléatoire entre 00 et 99      |
| #       | Symbole aléatoire parmi @ # ! \$ % & |

| Élément | Description       |
|---------|-------------------|
| 1       | Numéro du service |

Exemple : **TH-LE-09#1**

C'est le mot de passe par défaut de l'utilisateur, par la suite il pourra le changer si ils les veulent mais on acceptera pas tout le type de mot de passe. Afin de garantir un niveau de sécurité suffisant, tous les formats de mots de passe ne sont pas autorisés et une **politique stricte** est appliquée au niveau du domaine.

Le mot de passe initial des utilisateurs suit une convention définie, mais l'utilisateur est tenu de respecter les **règles de sécurité** lors de toute modification ultérieure. Ces règles ont pour objectif de réduire les risques liés aux accès non autorisés et aux compromissions de comptes.

## Bonnes pratiques pour les mots de passe :

- Utilisation de **minimale de 12 caractères**.
- Doit inclure **des lettres majuscules et minuscules, des chiffres, et des caractères spéciaux**.
- Le changement de mot de passe peut être suggéré régulièrement pour renforcer la sécurité.
- **Stratégie de verrouillage de compte au niveau du domaine**
  - Account lock threshold → 3 attempts
  - Account lock duration → 2 minutes
  - Reset timer after → 2 minutes

Après la création de son compte, chaque utilisateur reçoit une **communication dédiée** présentant les règles et recommandations relatives à la gestion des mots de passe. Cette communication vise à **sensibiliser l'utilisateur aux enjeux de sécurité** et à l'encourager à remplacer le mot de passe initial par un mot de passe personnel conforme aux exigences définies.

## Politique de sécurité

La politique de sécurité doit garantir la protection cohérente de l'environnement informatique. Elle inclura des pratiques pour la **gestion des mots de passe**, le **verrouillage des comptes** et l'application de paramètres système à l'aide des **stratégies de groupe (GPO)**. Ces mesures sont mises en place pour limiter les risques liés aux **accès non autorisés** et renforcer la **fiabilité** du système d'information.

- **Méthodologie de cloisonnement logique de l'annuaire AD et du SI :**

La sécurité de l'Active Directory (AD) doit être gérée en suivant les recommandations de l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information). L'AD doit être isolé

selon des principes de cloisonnement logique, afin de limiter les impacts d'une compromission. Référence : [Guide ANSSI - Méthodologie de cloisonnement logique de l'annuaire AD et du SI](#)

- **Les principes de sécurité CIA :**

- **Confidentialité** : Protéger les données sensibles contre les accès non autorisés.
- **Intégrité** : Garantir que les données ne soient pas modifiées de manière non autorisée.
- **Disponibilité** : S'assurer que les services sont accessibles quand ils sont nécessaires.

Les politiques de sécurité et les conventions de nommage des mots de passe doivent être rigoureusement appliquées dans l'environnement Active Directory pour garantir la protection des données et la sécurité des accès. L'intégration de la **méthodologie de cloisonnement** de l'ANSSI, des **principes CIA**, et des **stratégies de groupe (GPO)** aidera à maintenir une sécurité robuste et une gestion efficace des utilisateurs.

<https://cert.ssi.gouv.fr/politique-confidentialite-2321-4-1/>

<https://monespacenis2.cyber.gouv.fr/politique-confidentialite>

## Script pour la création d'utilisateur

```
Import-Module ActiveDirectory
```

*Pour vérifier si il n'y pas d'erreur*

```
Install-WindowsFeature RSAT-AD-PowerShell
```

*Taper cette commande si vous tomber sur une erreur*

Pour utiliser ce script, ouvrez **PowerShell** en tant qu'administrateur et collez le script dans la fenêtre PowerShell. Appuyez sur **Entrée** pour l'exécuter.

```
#####  
# Fonction : Génération d'un mot de passe complexe  
#####  
function Get-UserPassword {  
    param (  
        [string]$nom,  
        [string]$prenom,  
        [int]$service  
    )  
  
    # Vérification longueur pour éviter erreurs  
    if ($nom.Length -lt 2 -or $prenom.Length -lt 2) {
```

```

        throw "Le prénom et le nom doivent avoir au moins 2 lettres."
    }

    # Préfixes
    $nomPrefix = $nom.Substring(0, 2).ToUpper()
    $prenomPrefix = $prenom.Substring(0, 2).ToUpper()

    # Nombre aléatoire (10 à 99)
    $randomNumber = Get-Random -Minimum 10 -Maximum 99

    # Symbole aléatoire (renforce sécurité)
    $symbols = "@#!$%&"
    $randomSymbol = $symbols[(Get-Random -Minimum 0 -Maximum $symbols.Length)]

    # Format final : PR-NO-XX#S
    $password = "$prenomPrefix-$nomPrefix-$randomNumber$randomSymbol$service"

    return $password
}

```

```

#####
#  Fonction : Création d'un utilisateur Active Directory
#####
function Create-NewUser {

    Write-Host ""
    Write-Host "==== Création d'un utilisateur Active Directory ===" -
ForegroundColor Cyan

    # Demande des informations utilisateur
    $Nom = Read-Host "Entrez le nom de famille"
    $Prenom = Read-Host "Entrez le prénom"
    $Login = Read-Host "Entrez le login de l'utilisateur"
    $Email = Read-Host "Entrez l'email de l'utilisateur"
    $OU = Read-Host "Entrez l'OU (exemple : OU=Batiment A,DC=nawa,DC=net)"

    Write-Host ""
    Write-Host "Services disponibles :" -ForegroundColor Yellow
    Write-Host "1 - Direction"
    Write-Host "2 - Secrétariat"
    Write-Host "3 - Ressources Humaines"
    Write-Host "4 - Comptabilité"
    Write-Host "5 - Service Commercial"
    Write-Host "6 - Support Informatique"
    Write-Host "7 - Service Technique / Projets"
}

```



```

Write-Host "8 - Responsable Technique"
Write-Host ""

$Service = Read-Host "Entrez le numéro du service (1 à 8)"

# Conversion
$Service = [int]$Service

# Validation du service
if ($Service -lt 1 -or $Service -gt 8) {
    Write-Host "Numéro de service invalide, utilisation de 1 (Direction)" -
ForegroundColor Red
    $Service = 1
}

# Génération du mot de passe
try {
    $MotDePasse = Get-UserPassword -nom $Nom -prenom $Prenom -service
$Service
} catch {
    Write-Host $_ -ForegroundColor Red
    return
}

# Création AD
try {
    New-ADUser -Name "$Prenom $Nom" `
        -DisplayName "$Prenom $Nom" `
        -GivenName $Prenom `
        -Surname $Nom `
        -SamAccountName $Login `
        -UserPrincipalName $Email `
        -EmailAddress $Email `
        -Path $OU `
        -AccountPassword (ConvertTo-SecureString -AsPlainText
$MotDePasse -Force) `
        -ChangePasswordAtLogon $true `
        -Enabled $true

    Write-Host ""
    Write-Host "===== " -
ForegroundColor Green
    Write-Host "Utilisateur $Login créé avec succès !" -ForegroundColor
Green
    Write-Host "Mot de passe généré : $MotDePasse" -ForegroundColor Yellow
    Write-Host "===== "

```

```

    }
    catch {
        Write-Host "Erreur lors de la création de l'utilisateur : $_" -
ForegroundColor Red
    }
}

#####
#   Boucle pour créer plusieurs utilisateurs
#####
do {
    Create-NewUser
    $Continuer = Read-Host "Souhaitez-vous créer un autre utilisateur ? (O/N)"
} while ($Continuer -match "^[Oo]$")

Write-Host "Création des utilisateurs terminée." -ForegroundColor Cyan

```

Lorsque vous exécutez le script, il vous demande les informations suivantes pour chaque utilisateur

```

=== Création d'un utilisateur Active Directory ===
Entrez le nom de famille: Bob
Entrez le prénom: Dylan
Entrez le login de l'utilisateur: dylan
Entrez l'email de l'utilisateur: bobydylan@gmail.com

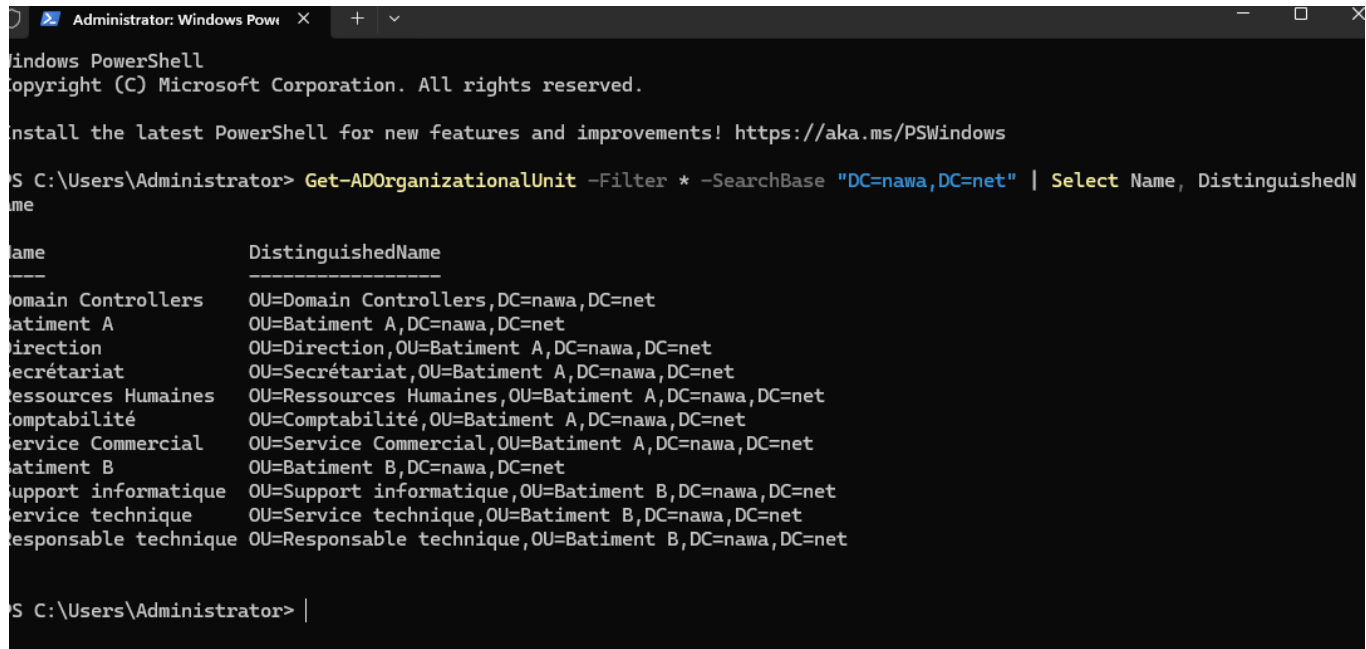
```

- **Nom de famille** : Entrez le nom de l'utilisateur.
- **Prénom** : Entrez le prénom de l'utilisateur.
- **Login** : Choisissez un identifiant (login) pour l'utilisateur.
- **Email** : Entrez l'email de l'utilisateur (doit être unique).
- **OU (Unité d'organisation)** : Indiquez le chemin dans lequel l'utilisateur sera créé dans Active Directory

Il faut faire attention à spécifier le bon chemin, sinon le code ne fonctionnera pas. Pour vérifier si le chemin est bien configuré, voici la commande :

```
Get-ADOrganizationalUnit -Filter * -SearchBase "DC=pipalap,DC=net" | Select Name, DistinguishedName
```

Cette commande affiche toutes les unités d'organisation (OU) présentes dans le domaine \_pipalap.net\_, en recherchant à partir de la racine DNS spécifiée, puis elle liste pour chacune son nom et son chemin complet



```
Administrator: Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> Get-ADOrganizationalUnit -Filter * -SearchBase "DC=nawa,DC=net" | Select Name, DistinguishedName

Name                                DistinguishedName
----                                -
Domain Controllers                  OU=Domain Controllers,DC=nawa,DC=net
Batiment A                          OU=Batiment A,DC=nawa,DC=net
Direction                          OU=Direction,OU=Batiment A,DC=nawa,DC=net
Secrétariat                        OU=Secrétariat,OU=Batiment A,DC=nawa,DC=net
Ressources Humaines                OU=Ressources Humaines,OU=Batiment A,DC=nawa,DC=net
Comptabilité                       OU=Comptabilité,OU=Batiment A,DC=nawa,DC=net
Service Commercial                 OU=Service Commercial,OU=Batiment A,DC=nawa,DC=net
Batiment B                         OU=Batiment B,DC=nawa,DC=net
Support informatique               OU=Support informatique,OU=Batiment B,DC=nawa,DC=net
Service technique                  OU=Service technique,OU=Batiment B,DC=nawa,DC=net
Responsable technique              OU=Responsable technique,OU=Batiment B,DC=nawa,DC=net

PS C:\Users\Administrator> |
```

Pour être sûr du chemin, copie-colle directement le chemin après avoir exécuté la commande.

```
=== Création d'un utilisateur Active Directory ===
Entrez le nom de famille: Bob
Entrez le prénom: Dylan
Entrez le login de l'utilisateur: dylan
Entrez l'email de l'utilisateur: bobbydylan@gmail.com
Entrez l'OU (exemple : OU=Batiment A,DC=nawa,DC=net): OU=Ressources Humaines,OU=Bâtiment A,DC=pipalap,DC=net

Services disponibles :
1 - Direction
2 - Secrétariat
3 - Ressources Humaines
4 - Comptabilité
5 - Service Commercial
6 - Support Informatique
7 - Service Technique / Projets
8 - Responsable Technique

Entrez le numéro du service (1 à 8): 3

=====
Utilisateur dylan créé avec succès !
Mot de passe généré : DY-B0-33$3
=====
Souhaitez-vous créer un autre utilisateur ? (O/N):
```

## Stratégie de Sauvegarde et de Disponibilité

Vous avez déjà un serveur de stockage, donc il n'est pas nécessaire que je vous en recommande un, mais voici la bonne méthode de sauvegarde.

La méthode :

3.2.1.1.0



3 : Dans l'AD il est important d'avoir plusieurs copies des données comme les informations de configuration du domaine et les données des utilisateurs.

La première copie de vos données Active Directory est l'original, qui se trouve directement sur vos serveurs AD. C'est la version principale des informations concernant vos utilisateurs, groupes, et paramètres de domaine.

La deuxième copie doit être stockée localement sur un autre support, comme un autre serveur ou un disque dur externe dans vos locaux. Cela vous permet de disposer d'une copie de secours à proximité, qui peut être rapidement restaurée en cas de panne ou de défaillance d'un serveur.

La troisième copie des données AD doit être stockée hors site, idéalement dans le cloud ou sur un serveur dans un autre centre de données. Vous pouvez utiliser des services comme **Azure Backup** ou **AWS S3** pour stocker vos sauvegardes dans un environnement sécurisé à distance.

2 : Faire des sauvegardes sur disques durs externes et des sauvegardes dans le cloud. Cette diversification réduit les risques associés à une défaillance d'une seule technologie et assure une disponibilité continue des données.

1 : Avoir une copie de sauvegarde stockée hors du site principal pour se protéger, une copie stockée sur le cloud ou un centre de données externe peut garantir que les informations. Si un incident survient dans vos locaux, vous pouvez récupérer vos données Active Directory depuis le cloud, comme **Azure** ou **AWS**, assurant ainsi la continuité des services.

1 : Pour se protéger contre les ransomwares ou toute autre forme d'attaque en ligne, il est essentiel d'avoir des sauvegardes qui ne sont pas accessibles directement depuis le réseau principal. Faire le stockage sur un serveur isolé vous permettra d'éviter d'être attaqué puisque pour récupérer vos données vous devez avoir une connexion physique.

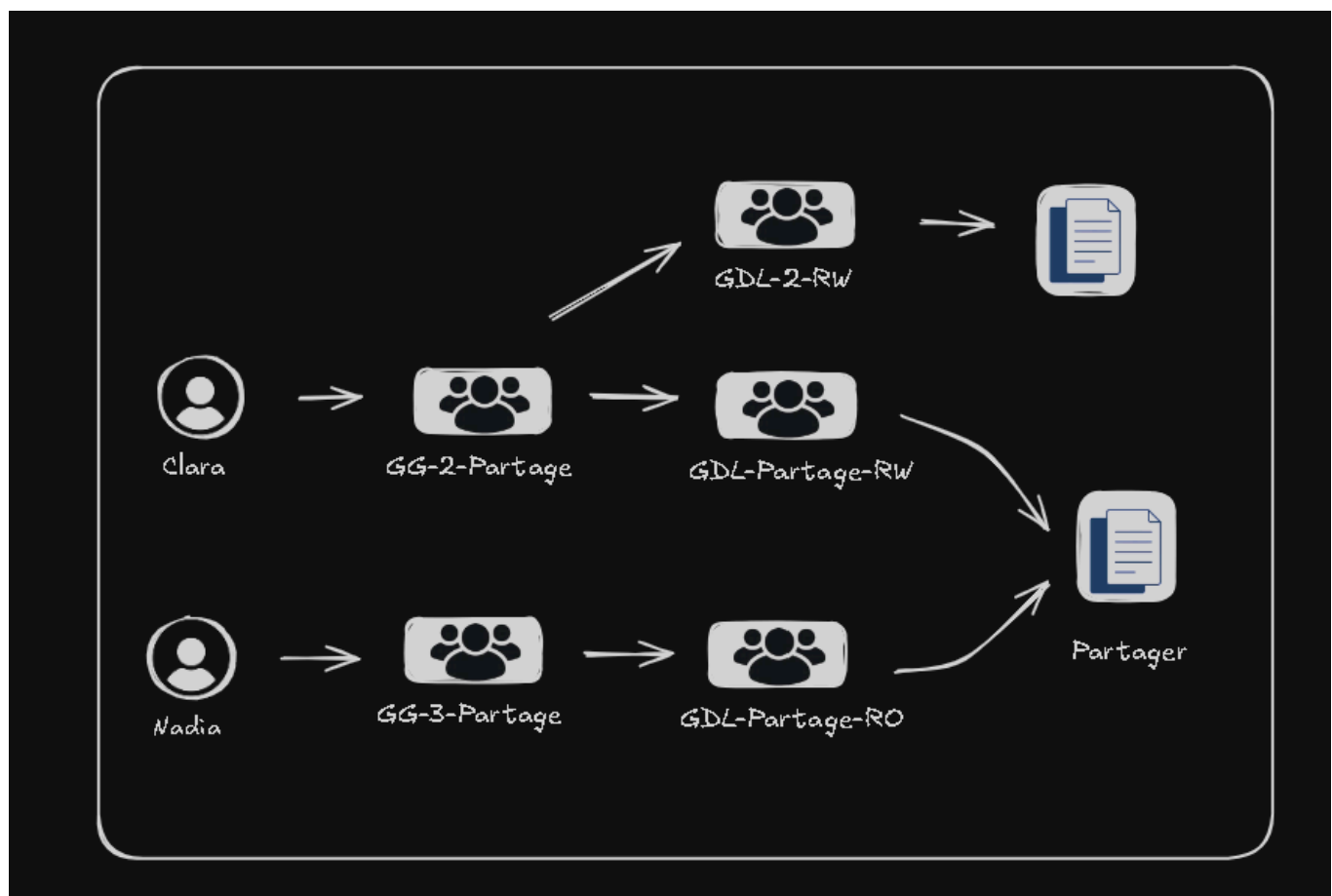
0 : Erreur lors des tests de restauration, il faut aucune pour la restauration des données. Tester régulièrement les sauvegardes est essentiel pour s'assurer qu'elles fonctionnent correctement. Si une restauration échoue, cela peut entraîner une perte de données importante.

En appliquant la méthode **3-2-1-1-0** à l'Active Directory, vous vous assurez que l'infrastructure AD est protégée contre différents types de risques, tout en facilitant une récupération rapide et fiable en cas d'accident.

L'idée dernière la gestion d'accident c'est d'être prêt à réagir à temps en cas d'incident pour minimiser les dommages et permettre une reprise rapide des services d'autant plus que c'est l'Active Directory qui gère les utilisateurs et les services d'une entreprise, ce qui est important de ce protéger à ce niveau là.

## Gestion de droits de fichiers

- Méthode AGDLP



Convention de Nommage :



GG-<Numéro Service>-<Objectif>

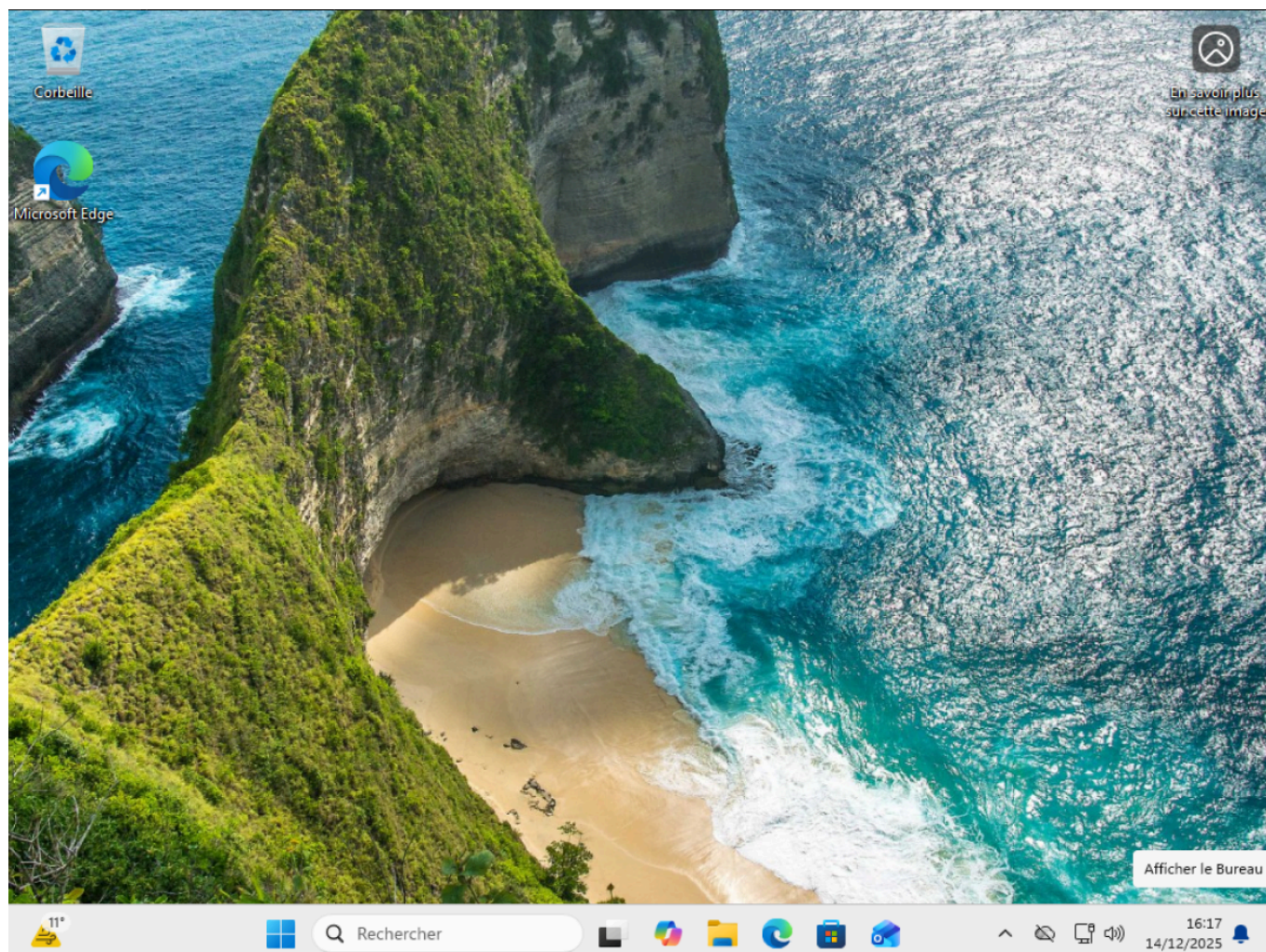
- GG : Groupe Générique
- Numéro Service

Le schéma illustre la gestion des accès et des permissions pour deux utilisateurs, **Clara** et **Nadia**, au sein de groupes de partage, en fonction de leur rôle et des permissions attribuées à chaque groupe.

Le schéma montre comment **Clara** bénéficie d'un accès complet aux ressources partagées, avec des droits en lecture et écriture, tandis que **Nadia** n'a qu'un accès en lecture seule aux mêmes ressources. La structure des groupes garantit que chaque utilisateur a les permissions appropriées à ses besoins professionnels, respectant ainsi les principes de gestion des accès et de sécurité des informations dans un environnement de travail collaboratif. Cependant, à la demande du client seule la direction dispose de tous les droits pour le partage de fichiers.

## Besoins clients

- Un fond d'écran commun



Comment vous protéger contre la vulnérabilité *PrintNightmare*, nous mettrons en place une GPO de protection.

Voici les recommandations à appliquer pour se protéger contre cette vulnérabilité.

**[Actualisé le 24 juillet 2021] Actuellement, voici l'état de la situation quant à la résolution de cette vulnérabilité :**

Le correctif publié par Microsoft en urgence pour protéger les machines contre la vulnérabilité PrintNightmare serait partiellement inefficace. Par "*partiellement inefficace*", cela signifie qu'il protège les machines contre l'exécution de code malveillant à distance, mais que l'élévation de privilèges en local (privilèges SYSTEM) semble toujours possible. Pour exploiter cette vulnérabilité, l'attaquant peut inciter l'utilisateur à ouvrir un document malveillant.

Ce nouvel état donne lieu à une nouvelle référence CVE : **CVE-2021-34481**. A ce jour, il n'existe pas de correctif pour cette vulnérabilité.

Tout d'abord, il est **recommandé de désactiver le service Spouleur d'impression sur les contrôleurs de domaine et sur tous les serveurs où le spouleur d'impression n'est pas utile** (*ce service gère les interactions entre votre machine et les imprimantes*).

Pour définir le type de démarrage "**Désactivé**" sur le service "**Spouleur d'impression**" ou "**Print Spooler**" en anglais. Voici la commande PowerShell qui permet d'effectuer cette configuration :

```
Set-Service -Name Spooler -StartupType Disabled
```

Une fois que le type de démarrage du service est modifié, il faut arrêter le service. En PowerShell, cela donne :

```
Stop-Service -Name Spooler
```

Nous avons désactivé le service **Spouleur d'impression** sur les contrôleurs de domaine et les serveurs non essentiels, conformément aux recommandations de l'**ANSSI** et de la **CISA** (Cybersecurity and Infrastructure Security Agency). Cela empêche l'exploitation de la vulnérabilité, tout en maintenant l'impression fonctionnelle sur les postes de travail non affectés.

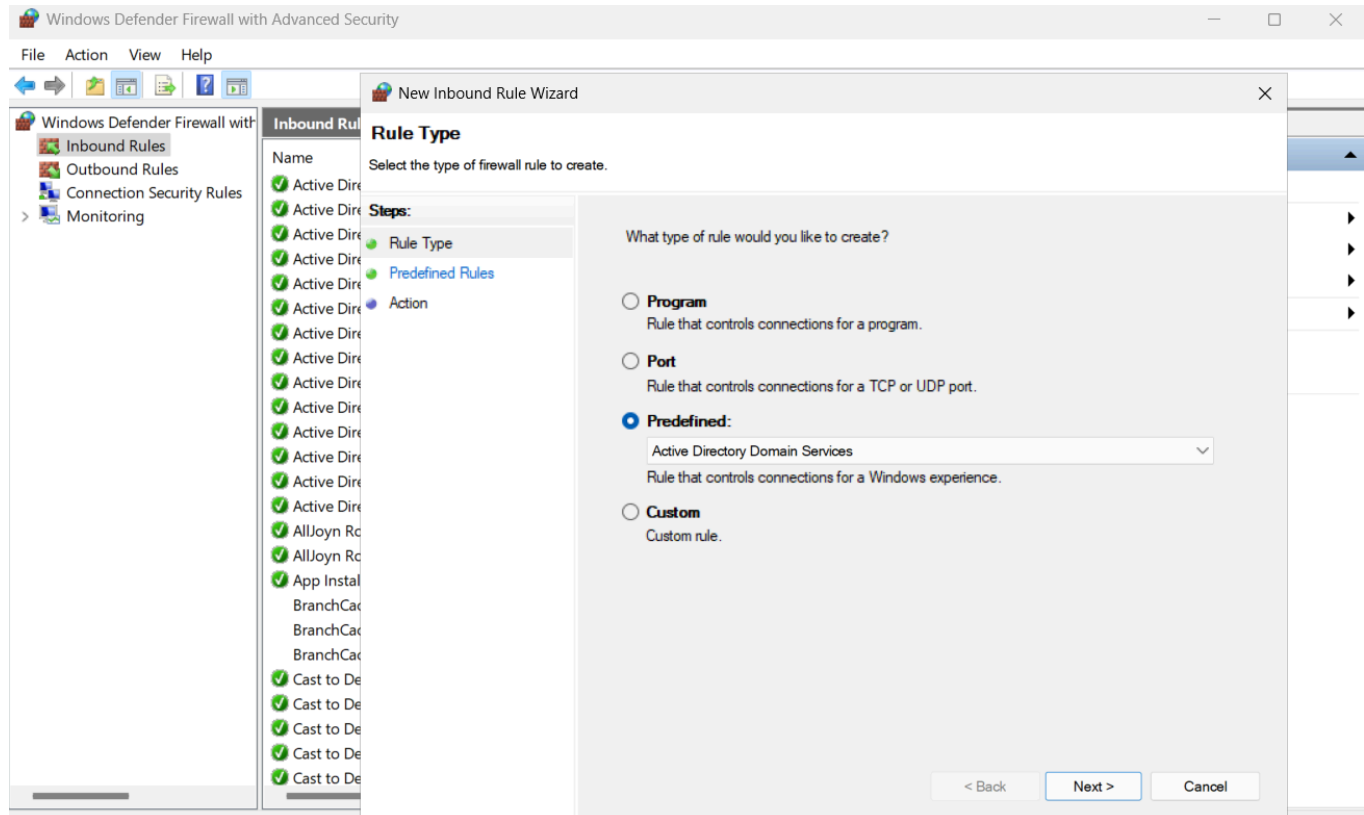
Afin de durcir la configuration du service **Spouleur d'impression**, nous avons configuré des clés de registre spécifiques et appliqué une **GPO** pour limiter les connexions à distance. Ces actions suivent les recommandations de **Microsoft** pour minimiser les risques d'exploitation, notamment :

- La configuration des clés de registre `NoWarningNoElevationOnInstall` et `NoWarningNoElevationOnUpdate` à `0`, selon les bonnes pratiques établies par **Microsoft**.

- L'activation de la GPO pour **désactiver le service Spouleur d'impression** sur les serveurs où il n'est pas nécessaire, et désactiver les connexions distantes pour éviter toute attaque par ce vecteur.

Enfin la configuration du pare-feu Windows

Le pare-feu Windows a été configuré pour bloquer les connexions entrantes sur les ports **445 et 139**, qui sont utilisés par le protocole SMB et pourraient permettre une exploitation de la vulnérabilité. Nous avons également configuré des règles spécifiques pour bloquer l'accès au processus `spoolsv.exe` sur les postes de travail.

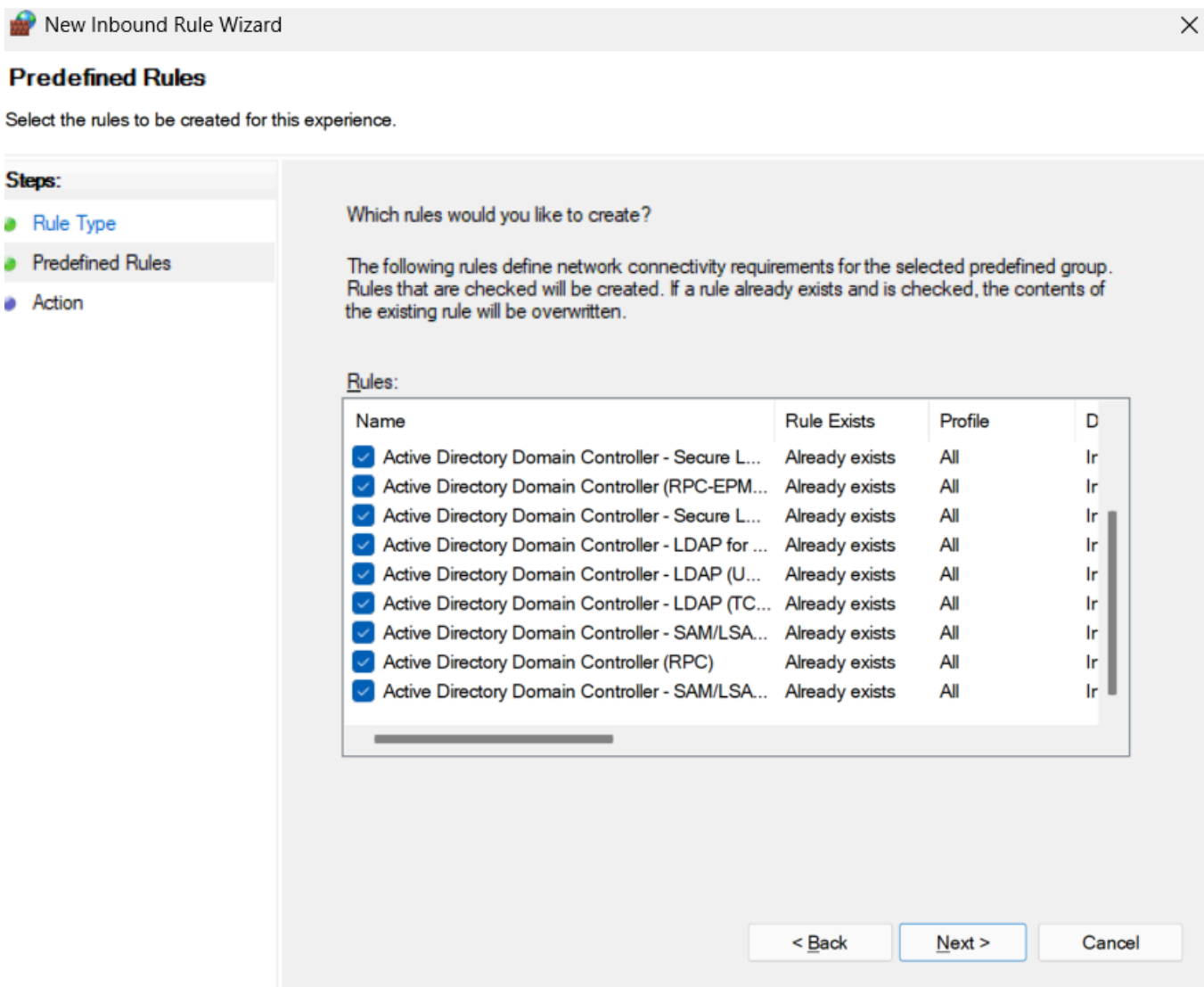


Nous avons **créé** une nouvelle règle de trafic entrant via un clic droit : un assistant va démarrer.

Pour le type de règle, il n'est pas nécessaire de créer une règle personnalisée, le besoin **correspond** à un modèle prédéfini. Le modèle « *Partage de fichiers et d'imprimantes* » est donc retenu. »

Nous avons **coché** toutes les règles pour tout bloquer, sauf pour le protocole SMB pour l'accès distant aux fichiers des machines, c'est ce qui pourrait vous gêner éventuellement plus tard pour cela nous ne l'avons pas **bloqué**. Autorisé uniquement sur certaines machines pour des besoins fonctionnels, tels que le NAS, les contrôleurs de domaine ou les postes d'administration





Références utilisées pour la mise en place de ces mesures :

- **ANSSI** (Agence nationale de la sécurité des systèmes d'information) : recommandations sur la gestion des vulnérabilités liées au **spouleur d'impression**.
- **CERT-FR** : Bulletins de sécurité et conseils de sécurité pour prévenir les exploits de la vulnérabilité **PrintNightmare**.
- **Microsoft** : publication officielle des correctifs de sécurité et les **guides de sécurité** relatifs à **PrintNightmare**.

## Indice de performance

```
\==--0---      PingCastle (Version 3.3.0.1      25/09/2024 12:03:40)
 \  / \  " ">
  0"--0'
   \ , '
    v

Get Active Directory Security at 80% in 20% of the time
End of support: 2026-01-31
To find out more about PingCastle, visit https://www.pingcastle.com
For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
For support and questions:
- Open-source community, visit https://github.com/netwrix/pingcastle/issues
- Customers, visit https://www.netwrix.com/support.html

What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main fonctionnality of PingCastle. In a matter of minutes, it produces a report which will give you an overv
iew of your Active Directory security. This report can be generated on other domains by using the existing trust links.
```

L'objectif de PingCastle est d'auditer l'annuaire Active Directory afin d'évaluer sa sécurité et son niveau de conformité en utilisant des critères et des bonnes pratiques standards. Cela permet de détecter des vulnérabilités potentielles, de fournir des recommandations d'amélioration et d'assurer une gestion proactive des risques liés à l'Active Directory

## pipalap.net - Healthcheck analysis

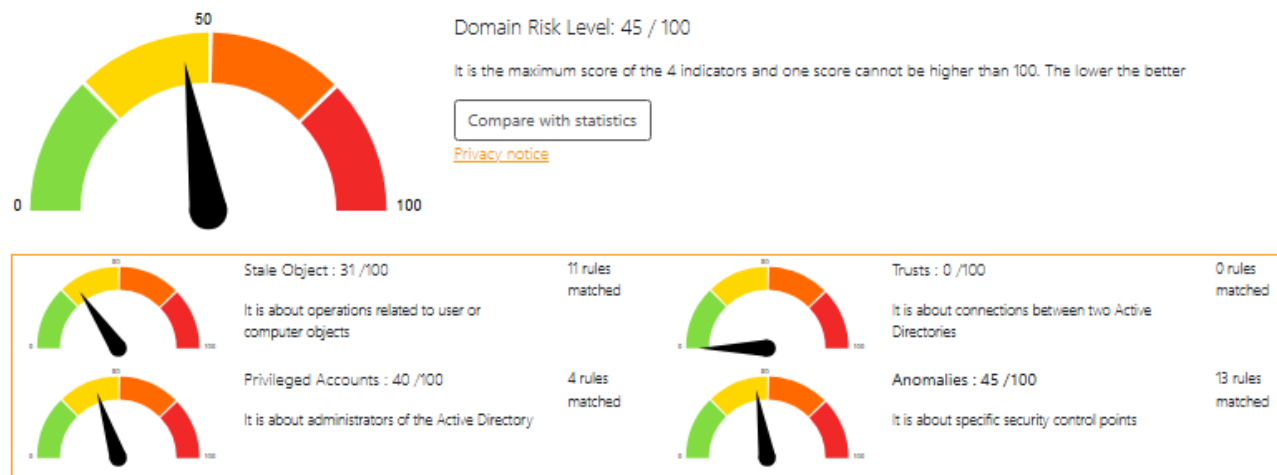
Date: 2025-12-14 - Engine version: 3.3.0.1

This report has been generated with the Basic Edition of PingCastle .  
**Being part of a commercial package is forbidden** (selling the information contained in the report).  
If you are an auditor, you **MUST** purchase an Auditor license to share the development effort.  
You are not using a supported version of PingCastle.

### Active Directory Indicators

This section focuses on the core security indicators.  
Locate the sub-process determining the score and fix some rules in that area to get a score improvement.

#### Indicators



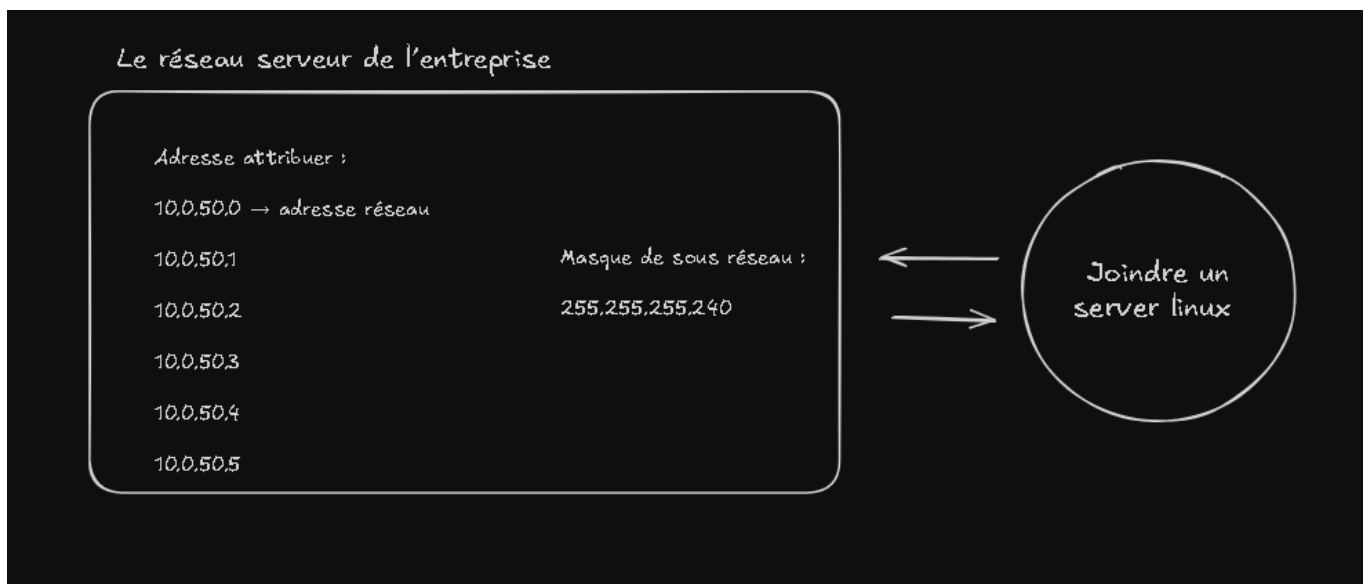
## Risk model ?

| Stale Objects                | Privileged accounts          | Trusts               | Anomalies                 |
|------------------------------|------------------------------|----------------------|---------------------------|
| Inactive user or computer    | Account take over            | Old trust protocol   | Audit                     |
| Network topography           | ACL Check                    | SID Filtering        | Backup                    |
| Object configuration         | Admin control                | SIDHistory           | Certificate take over     |
| Obsolete OS                  | Control paths                | Trust impermeability | Golden ticket             |
| Old authentication protocols | Delegation Check             | Trust inactive       | Local group vulnerability |
| Provisioning                 | Irreversible change          | Trust with Azure     | Network sniffing          |
| Replication                  | Privilege control            |                      | Pass-the-credential       |
| Vulnerability management     | Read-Only Domain Controllers |                      | Password retrieval        |
|                              |                              |                      | Reconnaissance            |
|                              |                              |                      | Temporary admins          |
|                              |                              |                      | Weak password             |

Legend:

- score is 0 - no risk identified but some improvements detected
- score between 1 and 10 - a few actions have been identified
- score between 10 and 30 - rules should be looked with attention
- score higher than 30 - major risks identified

## Poste Linux



C'est tout à fait possible de joindre une machine linux à un domaine Active Directory et voici la procédure pour le mettre en œuvre.

La première chose à faire c'est de s'assurer que votre OS utilise bien le bon DNS, celui de Windows Server :

```
sudo nano /etc/resolv.conf
```

Le résultat :

```
search pipalap.net nameserver 10.0.50.10 nameserver
```

2a01:e0a:4e8:fab1:c04a:99ff:fefa:4a60

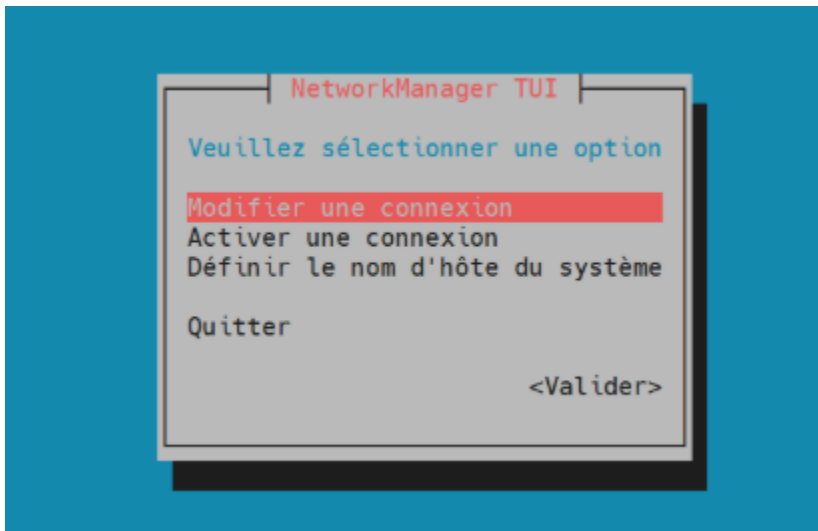
*La machine utiliser est une distribution linux Debian 13, importe la distribution que vous voulez utiliser vous pouvez utiliser cette méthode*

Si vous n'avez pas les bonnes valeurs dans le fichier `resolv.conf` , inutile de les modifier à cet endroit car ce fichier est dynamique. Il est créé automatiquement au démarrage avec certaines valeurs.

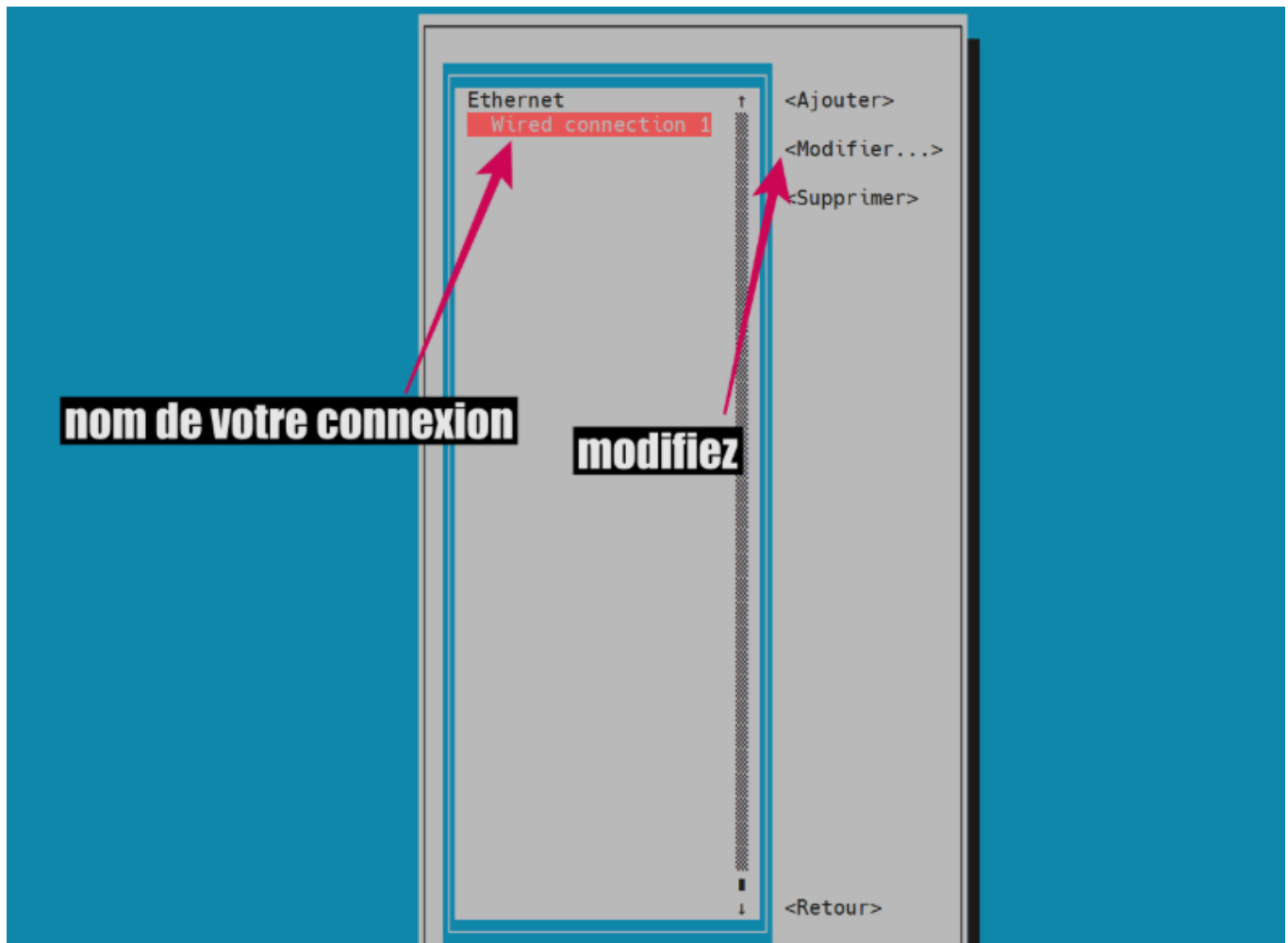
En ligne de commande, on utilise l'utilitaire " `nmtui` " pour modifier le DNS:

```
sudo nmtui
```

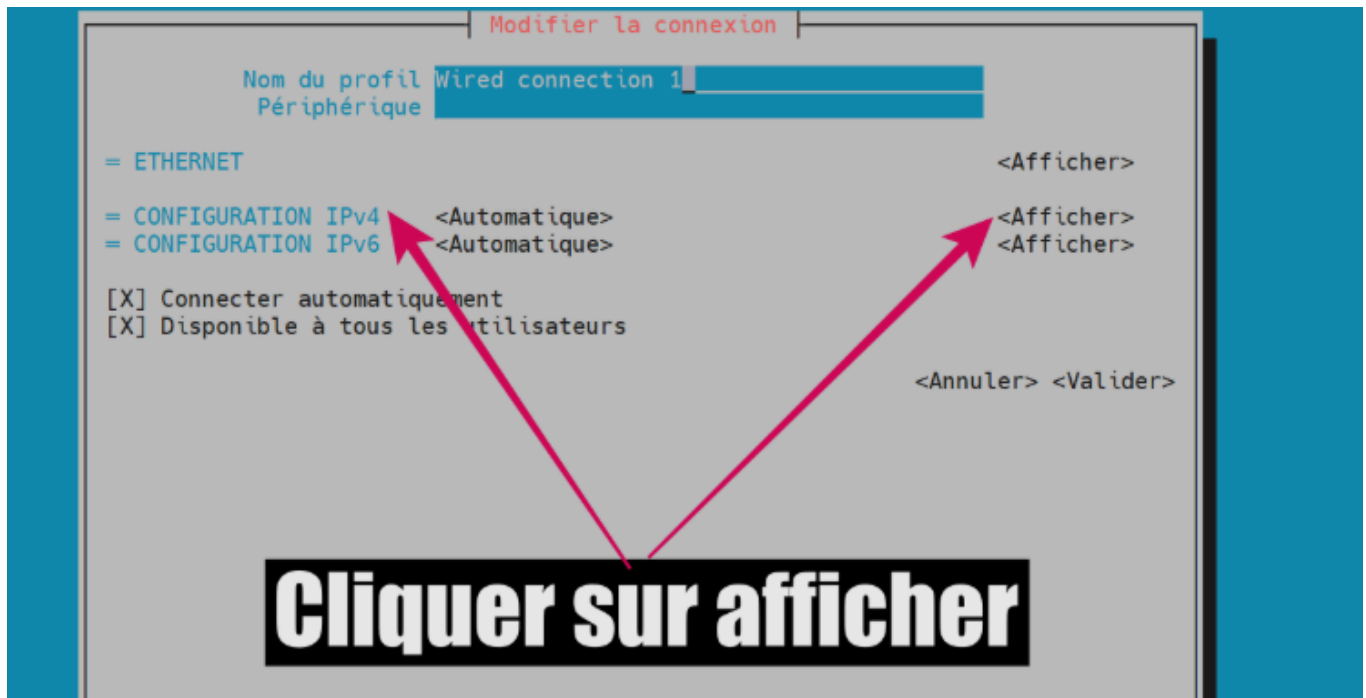
Etape 1 :



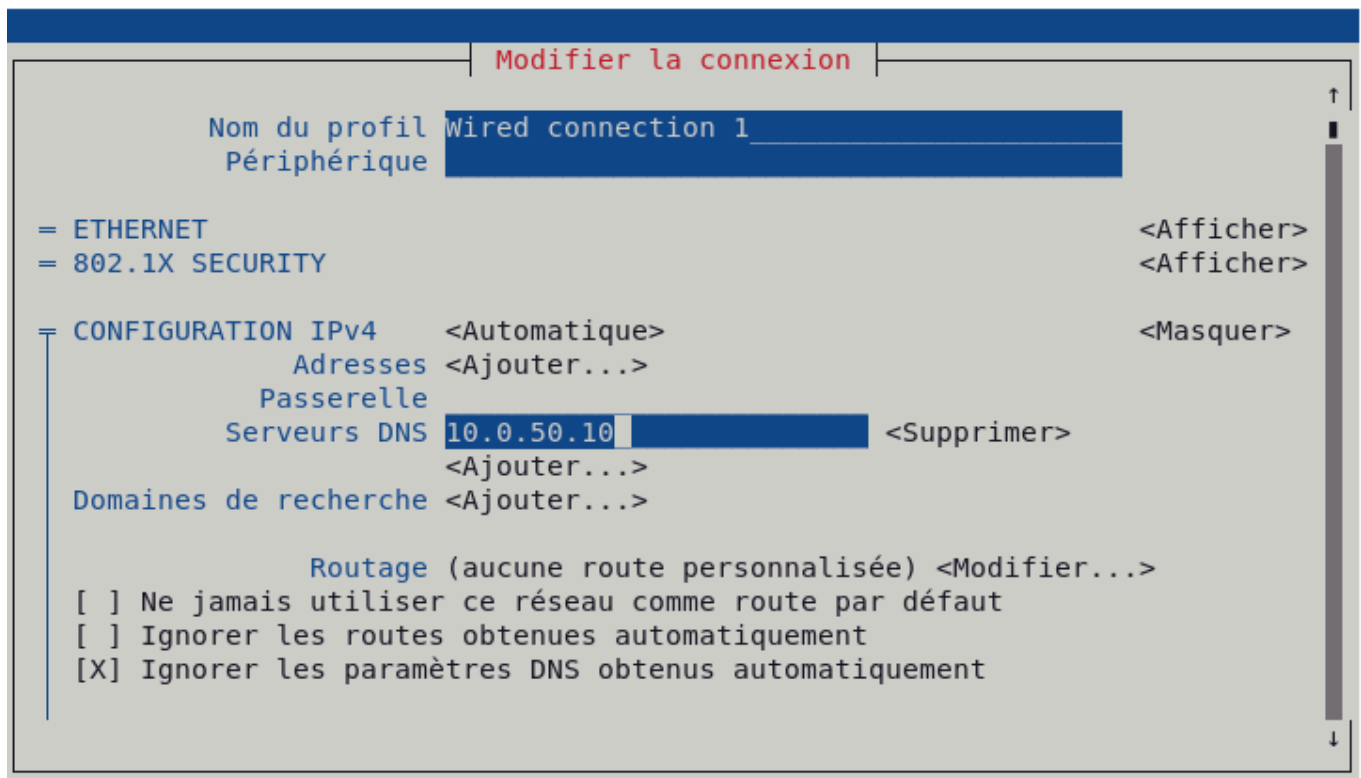
Etape 2 :



Modifier sur le nom de la connexion



Afficher la connexion IPv4



---> Ajouter un serveur DNS "10.0.10".

---> Cocher "ignorer les paramètres DNS obtenus automatiquement".

---> Valider

Redémarrez le réseau

```
sudo systemctl restart networking
```

On va ensuite modifier le fichier `hostname` de votre machine :

```
sudo nano /etc/hostname
```

Vous avez un nom dans ce fichier, il correspond au nom qui identifie votre machine, vous pouvez le modifier pour qu'il soit plus explicite.

Dans l'exemple, ce sera `sta-debian`

On va ensuite modifier le fichier `hosts`

```
sudo nano /etc/hosts
```

```
nawa@debian: ~  
127.0.0.1      localhost  
127.0.1.1      debian.nawa.net      debian  
10.0.50.10     WIN-7B48KNEAE42.pipalap.net ad-win  
# The following lines are desirable for IPv6 capable hosts  
::1           localhost ip6-localhost ip6-loopback  
ff02::1 ip6-allnodes  
ff02::2 ip6-allrouters  
~  
~  
~
```

- Le 127.0.0.1 correspond a votre machine dans la boucle local
- Le 127.0.1.1 correspond au nom de votre machine sur le réseau,  
On vérifie que c'est le bon `hostname` et le nom de domaine du réseau qui est indiqué !!
- Le 10.0.50.10 est l'adresse du serveur DNS.

On va ensuite installer tous les outils nécessaires pour notre Debian

```
sudo apt update && sudo apt upgrade -y
```

```
sudo apt -y install realmd libnss-sss libpam-sss sssd sssd-tools adcli samba-  
common-bin oddjob oddjob-mkhomedir packagekit
```

Cette ligne installe **Realmd** qui le système qui permet de créer la jonction avec Active Directory.

On ajoute notre machine au Domaine "pipalap.net"

Le résultat :

```
configured: no  
server-software: active-directory  
client-software: sssd  
required-package: sssd-tools  
required-package: sssd  
required-package: libnss-sss  
required-package: libpam-sss  
required-package: adcli  
required-package: samba-common-bin
```

Comme vous pouvez le voir, ce n'est pas encore configuré. On va ensuite permettre à un utilisateur "Active Directory" de se connecter et de créer un répertoire personnel sur notre Debian :

Copiez cette chaîne de commande complète :

```
sudo bash -c "cat > /usr/share/pam-configs/mkhomedir" <<EOF
Name: activate mkhomedir
Default: yes
Priority: 900
Session-Type: Additional
Session:
    required                                pam_mkhomedir.so umask=0022 skel=/etc/skel
EOF
```

Une petite explication sur ce "petit script" qui n'en est pas un...

- `bash -c` indique l'exécution d'une chaîne de commandes à venir
- `cat` va créer le fichier `mkhomedir`
- `EOF` indique le début et la fin de la saisie de plusieurs lignes dans le fichier `mkhomedir`

Le reste est ce que contient le fichier **mkhomedir**

```
Name: activate mkhomedir # Active mkhomedir
Default: yes # Par défaut
Priority: 900 # Le niveau de priorité dans le démarrage du système
Session-Type: Additional # Créé une nouvelle session
Session:
    required                                pam_mkhomedir.so umask=0022 skel=/etc/skel # C
```

Vous pouvez lire le fichier pour vous en assurer

```
sudo nano /usr/share/pam-configs/mkhomedir
```

On va joindre ce coup-ci la station Debian au domaine

```
sudo realm join -U administrateur pipalap.net
```

Il vous demande le mot de passe de l'administrateur du serveur "ad-win"

Si aucun message d'erreur n'apparaît, c'est déjà pas mal !

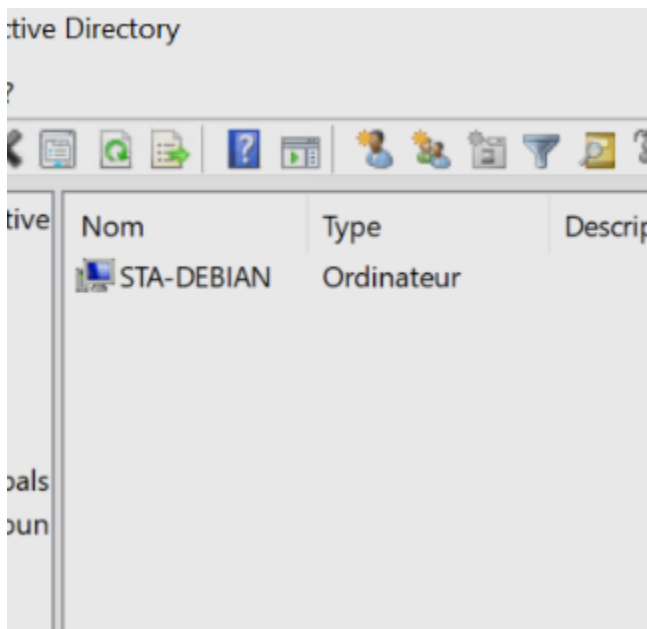
Pour vérifier cette connexion avec le domaine, on utilise la commande

```
sudo realm list
```



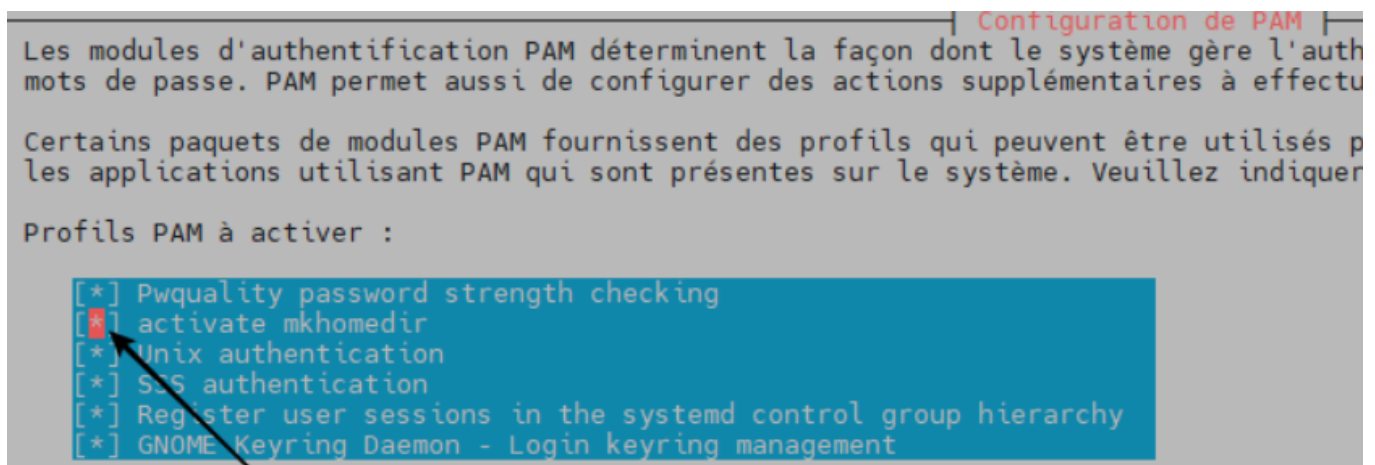
```
rzo.lan
type: kerberos
realm-name: RZO.LAN
domain-name: rzo.lan
configured: kerberos-member
server-software: active-directory
client-software: sssd
required-package: sssd-tools
required-package: sssd
required-package: libnss-sss
required-package: libpam-sss
required-package: adcli
required-package: samba-common-bin
login-formats: %U@rzo.lan
login-policy: allow-realm-logins
```

Maintenant c'est configuré, ce qui veut dire que nous avons rejoint le domaine !



Nous allons activer le module « pam » qui gère l'authentification sur le "mkhomedir" c'est la ligne qui est inscrite dans le fichier du même nom.

```
sudo pam-auth-update
```



On redémarre le service `sssd`

```
sudo systemctl restart sssd
```

On vérifie son statut

```
sudo systemctl status sssd
```

```
sssd.service - System Security Services Daemon
Loaded: loaded (/lib/systemd/system/sssd.service; enabled; vendor preset: enabled)
Active: active (running) since Wed 2024-04-17 22:35:48 CEST; 1min 34s ago
Main PID: 2579 (sssd)
Tasks: 4 (limit: 4644)
Memory: 45.2M
CPU: 323ms
CGroup: /system.slice/sssd.service
├─2579 /usr/sbin/sssd -i --logger=files
├─2580 /usr/libexec/sssd/sss_d_be --domain rzo.lan --uid 0 --gid 0 --logger=files
├─2582 /usr/libexec/sssd/sss_d_nss --uid 0 --gid 0 --logger=files
└─2583 /usr/libexec/sssd/sss_d_pam --uid 0 --gid 0 --logger=files
```

On connecte un utilisateur AD à notre station Debian

```
userse@sta-debian:~$ id tom@pipalap.net
```